

NOTE 05 — PHISHING

What is phishing?

Phishing is a social-engineering attack where an attacker attempts to trick a victim into revealing information, opening malicious content, transferring money, or performing another action.

Phishing commonly uses:

- Email
- SMS
- Messaging applications
- Fake websites
- Social media
- Phone calls

Common signs of phishing

1. Suspicious sender

The sender's address may imitate a legitimate organization.

2. Urgency

Examples:

Your account will be deleted today!

3. Suspicious link

The visible text may not match the actual destination.

4. Unexpected attachment

An unexpected document or executable may be malicious.

5. Credential request

The message asks for:

- Password
- OTP
- Banking information
- Recovery code

6. Unusual language

Poor grammar or unusual formatting can be a warning sign, although professional-looking phishing messages also exist.

Fictional phishing email for training

Training example — do not send this to real users.

From: IT Security <security-training@example.invalid>

To: Employee <employee@example.invalid>

Subject: [TRAINING SIMULATION] Account Verification Required

Hello Employee,

Your account has been selected for a security-awareness exercise.

Please review your account security information using the training portal below:

[TRAINING LINK — FICTIONAL]

If you have any concerns, contact the IT Security team through the official company help desk.

Regards,

Security Awareness Team

TRAINING SIMULATION — NO REAL CREDENTIALS SHOULD BE ENTERED

Why could this resemble phishing?

A real attacker might use:

- Urgency
- Authority
- Account-related fear
- A malicious link
- A fake login page

How should a user respond?

1. Don't click suspicious links.
2. Verify the sender.
3. Visit the organization's official website manually.
4. Contact IT/security through a trusted channel.
5. Report suspicious messages.
6. Never provide passwords or OTPs through suspicious links.

SOC analyst role in phishing

A SOC analyst may investigate:

- Sender address
- Email headers
- URLs
- Domains
- IP addresses
- Attachments
- File hashes
- Authentication logs
- Endpoint activity

The analyst then determines whether the email is legitimate, suspicious, or malicious.